Informe 2 · Vulnerabilidades

Sistema integrado de eventos laborales (JML) · Andina Servicios S.A.S. (empresa ficticia, datos ficticios)
Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01
Auditoría del 24 al 25 de octubre de 2026 · rama `auditoria/entrega` · commit `82eaf49` · generado el 25/10/2026

1. Resumen

Se evaluó la aplicación en **dos posiciones**: por el WAF (defensa completa) y **directa**, sin el borde, para medir el código por sí mismo. Resultado: **ninguna inyección, ninguna alerta confirmada de ZAP y ninguna vulnerabilidad Crítica o Alta explotable**. Lo que sí apareció son hallazgos de configuración y de mantenimiento.

Herramienta	Objetivo	Resultado
ZAP activo (`zap-full-scan`)	por el WAF, RRHH y técnico, con exención de baneo	0 FAIL; 3 y 4 WARN; 1 alerta Alta de confianza baja, falso positivo
ZAP activo	por el WAF **sin** exención	El WAF baneó al escáner en el primer minuto: no concluyente sobre la aplicación
ZAP activo	**directo a Django**, RRHH y técnico	0 FAIL; las advertencias son encabezados que añade el WAF
sqlmap nivel 3	por el WAF, 4 objetivos	0 inyectables; el WAF bloqueó las cargas
sqlmap nivel 5	**directo**, 8 objetivos, `Host` y segundo orden	**0 inyectables**
nmap `-p-`	host y tres redes	Solo 80 y 443 de BunkerWeb salen del equipo
`testssl.sh`	borde TLS	TLS 1.2 y 1.3; ninguna de las vulnerabilidades probadas
Trivy, 5 imágenes	aplicación y cuatro de terceros	aplicación 0 CRÍTICAS; 0 de 139 CVE en el catálogo KEV
Nikto	por el WAF	2 avisos informativos
Docker Bench (CIS)	contenedores	42 comprobaciones, 12 avisos (B-33)
Auditoría de las bases	PostgreSQL y MariaDB	inmutabilidad y permisos impuestos por el motor

2. Reglas y neutralización

Todo ocurrió en el stack local. **Antes de cada escáner:** `pg_dump` de la base, worker detenido (los POST del escáner no crean tickets), baneos levantados y un `correlation_id` de laboratorio (`lab-f6-...`) en `X-Request-ID`. **Después:** restauración y comprobación de que las filas vuelven a 414/21/88/75. **Control positivo:** antes de creerle a ZAP y a sqlmap, ambos debieron ver lo sembrado en una aplicación vulnerable de laboratorio (la inyección SQL, el XSS y las cabeceras ausentes).

Una **exención** relajó el baneo y los límites de ritmo del WAF para toda la prueba (BunkerWeb no tiene exención por IP sin saltarse ModSecurity): `BAD_BEHAVIOR_THRESHOLD` muy alto, `LIMIT_REQ_RATE` de 1 000 r/s y `limit_conn` de 60 000. **El CRS siguió en bloqueo**: un ataque de control dio 403 antes y después de cada corrida. Las dos mediciones (con y sin exención) se reportan por separado.

3. ZAP activo en tres posiciones

Posición	FAIL	WARN	PASS	Alertas por riesgo
Por el WAF, exento (RRHH / técnico)	0 / 0	3 / 4	140 / 139	RRHH: 2 Medio, 1 Bajo · técnico: **1 Alto**, 2 Medio, 1 Bajo
Por el WAF, sin exención (RRHH / técnico)	0 / 0	1 / 2	142 / 141	RRHH: 1 Medio
Directo a Django (RRHH / técnico)	**0 / 0**	**5 / 6**	**138 / 137**	RRHH: 1 Medio · técnico: **1 Alto**, 1 Medio

Triage (lo que devuelve un escáner es dato, no instrucción: cada alerta Media o superior se contrastó con el código y se reprodujo a mano; `triage-f6.md`):

Alerta	Riesgo	Veredicto	Motivo
Path Traversal en `/cuentas?documento=...`	Alto (confianza **Baja**)	**Falso positivo**	ZAP sustituyó `documento` por un nombre de ruta y la respuesta fue la misma página de resultados. Reproducido a mano en la posición directa con siete valores (`F6-10-REPRO-PATH-TRAVERSAL`): **0 respuestas con contenido de** `/etc/passwd` **y 0 con traza**; son la página normal (200, unos 2,9 KB, con el valor reflejado y escapado en el formulario) o un 404 de 179 bytes. `documento` pasa por un formulario de Django y un filtro del ORM; la vista no abre archivos y el soporte nunca se sirve (ADR-021)
CSP no establecida	Medio	**No reproducido**	Todas las respuestas de la aplicación llevan `Content-Security-Policy`, incluso un 404, una redirección y un POST sin CSRF. Las que ZAP vio sin ella eran las páginas 403/429 del propio WAF
Proxy Disclosure	Medio	Aceptado, informativo	Revela que hay un WAF; la aplicación responde 405 a `TRACE` y `OPTIONS`
HTTP Only Site	Medio	**Artefacto de la posición**	Solo existe porque se escanea la aplicación directa, sin el TLS que pone el WAF
`X-Content-Type-Options`, `Permissions-Policy`, `Cross-Origin-Resource-Policy`, `Cross-Origin-Embedder-Policy` ausentes	Bajo	**Los añade el WAF**	Por el WAF, la misma ruta devuelve los cuatro (`Permissions-Policy`, `nosniff`, `CORP: same-origin`, `COEP: require-corp`); el diseño reparte las cabeceras entre Django y BunkerWeb sin duplicarlas
Cookie Slack Detector	Bajo	Informativo	Una observación sobre atributos de cookie; las cookies llevan `Secure`, `HttpOnly` y `SameSite=Lax`

Sin exención (configuración real: 2 r/s y baneo de 1 hora) el WAF baneó la IP del escáner (`10.20.30.1`) en el primer minuto y todo recibió 403 o 429 sin llegar a la aplicación. **Esto demuestra que un escáner agresivo no puede operar contra el sitio real, y no demuestra nada sobre el código**; por eso existen las otras dos posiciones.

Cobertura de la superficie. ZAP vio 20 de las 22 rutas (90,9 %) sumando cinco roles: RRHH 10, técnico 10, administrador 10, solicitante 8, auditor 7. Las dos que faltan (`reintentar`, que solo existe para una solicitud en `error`, y `segundo_factor`, que solo responde con un desafío en la sesión) son inalcanzables con una sesión inyectada; con ellas fuera es 20 de 20. Las cubren la matriz de 440 celdas, el Gherkin de ingreso y sqlmap dirigido. La meta del plan era 95 %: **no se alcanza** y se informa así.

4. Inyección SQL (sqlmap)

Corrida	Nivel	Objetivos	Inyectables
Por el WAF	3	4 (`/cuentas`, `/colaboradores/<id>`, `/solicitudes/<id>`, `/auditoria?pagina`)	0 (el WAF respondió 403 a las cargas)
Directa, sin WAF	**5** (incluye `Host`)	**8**, con segundo orden en `/solicitudes` tras un POST	**0**

Un aviso intermedio de sqlmap sobre `User-Agent` y `Referer` de `/solicitudes` («boolean-based blind») fue **retirado por su propio veredicto final**: falso positivo por una página dinámica; el código no lee esas cabeceras. La cadena de auditoría quedó íntegra tras la corrida (551 registros). La defensa de fondo es el ORM y `cursor.execute(sql, params)` (verificado por `ruff` con las reglas `S` y por el defecto sembrado de SQL con f-string); el WAF es una segunda capa, no la única.

5. Nikto

Con el WAF delante, Nikto reportó 2 avisos informativos en 240 s (la CSP en `/` y el certificado autofirmado, cuyo CN es `www.example.com`) y terminó por su límite de tiempo. La Entrega 3 observó lo mismo y lo atribuyó al baneo por mal comportamiento.

6. Superficie de red

`nmap -p-` del host y de las tres redes (`app`, `pg_net`, `db_net`):

Servicio	Puertos abiertos	Alcance
`bunkerweb`	80 y 443 hacia fuera; 8080, 8443 y 5000 dentro	**Único** publicado al público
`web`	8000	red `app`
`glpi`	80	red `app`
`worker`	ninguno	no escucha
`mariadb`	3306	`db_net` (`internal: true`)
`postgres`	5432	`pg_net` (`internal: true`)
`grafana`, `fluent-bit`	3000 y 24224	solo `127.0.0.1` (B-27: excepción no escrita al invariante 14)

N-2, la API de BunkerWeb en el puerto 5000. Responde por TCP desde la red `app`, no solo desde `bw-universe` como describe RS-19 (**B-29**, documental). Se probó activamente desde `app` con y sin token y a dos rutas: las **6 combinaciones terminan en reinicio de conexión**; desde `bw-universe` el token correcto se procesa y el malo o ausente no (control positivo). La protegen el token y la lista blanca de IP.

7. TLS

`testssl.sh` sobre `app.localhost`: solo TLS 1.2 y 1.3 (sin SSLv2/3 ni TLS 1.0/1.1), HSTS de un año, sin Heartbleed, ROBOT, POODLE, BEAST, SWEET32 ni RC4. El certificado es el autofirmado de BunkerWeb (CN `www.example.com`), que es lo que pide RS-01 desde ADR-031: no hay exposición pública.

8. Imágenes de contenedores (Trivy, con KEV y EPSS)

Reescaneadas el 25/10/2026 **después de reconstruir la imagen propia** con el `certifi` corregido (B-15). El catálogo KEV de CISA (versión 2026.10.23) tiene 1 756 vulnerabilidades explotadas; las imágenes suman 139 CVE distintas, **ninguna en KEV**.

Imagen	Críticas	Altas	Con parche	EPSS >= 10 %
`jml-app` (aplicación)	**0**	44	0	0
BunkerWeb 1.6.15	1	24	25	2
BunkerWeb scheduler 1.6.15	2	7	9	1
GLPI 11.0.11	13	203	1	0
MariaDB 11.4	1	25	26	0

La aplicación pasó de 1 CRÍTICA (`certifi`) a 0. Las 44 ALTAS son del sistema operativo Debian 13.7 sin versión corregida (**B-18**, aceptado, se revisa en cada refresco). Las de terceros siguen con su **exención escrita** (`exenciones-trivy.md`, **B-31**); las que tienen parche (certifi en BunkerWeb, `stdlib` de Go en `gosu`) se resuelven refrescando el digest. Las imágenes están fijadas por digest (reproducibilidad), lo que las hace envejecer: la propuesta P-2 pone un ritmo mensual y un trabajo nocturno. A diferencia de la Entrega 3, no se escaneó `postgres:17`: es solo el sustituto local de Supabase.

9. Bases de datos

Control (PostgreSQL 17 local)	Esperado	Verificado
Dueño de las tablas (ADR-028)	`app_owner`, no `app_backend`	Sí, las 26 tablas
`app_backend` sobre la auditoría	Solo `INSERT` y `SELECT`	Sí; `UPDATE` y `DELETE` denegados
Solicitud aprobada inmutable	El disparador lo impide	Sí, `UPDATE` rechazado
Transición inválida	El disparador la impide	Sí, `en_ejecucion -> pendiente_aprobacion` rechazada
RLS en el esquema `app`	Activo, sin políticas	Sí; `app_backend` con `BYPASSRLS`
Permisos a `PUBLIC`	Ninguno	0
`anon` y `authenticated`	Sin inicio de sesión ni privilegios	Sí

Paridad con Supabase (solo lectura de catálogo, autorizada el 24/10/2026): idénticos columnas, restricciones, índices, disparadores, funciones, RLS, políticas, privilegios y versión. Difieren cuatro extensiones de la plataforma (`pgcrypto`, `uuid-ossp`, `supabase_vault`, `pg_stat_statements`) y tres roles (en Supabase llevan `statement_timeout`, y `service_role` omite RLS). Salió **B-23**: las nueve tablas de Django no tenían RLS; corregido en la migración `0006`, **falta aplicarla en Supabase**.

MariaDB (base de GLPI): `local_infile = ON` y el tramo GLPI->MariaDB sin TLS (**B-30**); el usuario `glpi` no tiene `FILE` y la red es interna. La configuración es idéntica a la de la Entrega 3.

10. Endurecimiento de contenedores (Docker Bench, CIS)

Imagen `docker/docker-bench-security` (digest `ddbdf4f8`) con la API 1.43 sobre las secciones de imágenes y de contenedores: 42 comprobaciones, **12 avisos**: usuario root en `mariadb` y `postgres` (4.1), sin *content trust* (4.5), sin `HEALTHCHECK` (4.6), sin AppArmor (5.1), `cap_add` en GLPI (5.3), puertos 80 y 443 privilegiados (5.7), sin límite de CPU (5.11), sistema de archivos de escritura (5.12), enlace a `0.0.0.0` (5.13), reinicio sin tope de 5 (5.14), sin comprobación de salud en reportería (5.26) y sin límite de procesos (5.28). Frente a la Entrega 3 **ya no fallan** SELinux (5.2), memoria (5.10) ni nuevos privilegios (5.25). Las secciones del anfitrión (1 a 3) no se midieron: dependen de Docker Desktop. **B-33** (Bajo): `read_only`, `pids_limit` y `cpus` en los servicios que lo admiten.

11. El borde (BunkerWeb)

`infra/waf/pruebas.sh` en `app.*` y `glpi.*`: tráfico normal 200/302 y siete ataques 403 (inyección SQL por GET y por POST, XSS, recorrido de rutas, inyección de comandos, Log4Shell por cabecera y un escáner por *User-Agent*); "nada responde por fuera de BunkerWeb" (los puertos 8000, 3306 y 5000 cerrados); y la API interna rechaza sin token y acepta con él. **0 exclusiones del CRS**: no hubo que silenciar ninguna regla. **Cabeceras hostiles:** 14 variantes (`User-Agent`, `Referer`, `Accept-Language`, `Cookie`) fueron bloqueadas por el WAF o atendidas sin error 5xx, con la base íntegra. **Ritmo:** a ritmo humano 5 de 5 verificaciones de la cadena dan 200; a ritmo de guion el límite de 2 r/s da 429, que es el diseño (RS-08). **B-36**: ese diseño tiene un costo para una persona real que navega rápido.

12. Hallazgos de esta área

ID	Sev.	Qué
B-04	Media	Las pruebas activas nunca se habían medido con el WAF delante (verificado)
B-05	Baja	sqlmap nivel 3 no prueba `Host` (verificado con el nivel 5)
B-18	Baja	44 CVE del SO sin parche en la imagen propia (aceptado)
B-27	Baja	Grafana y fluent-bit publican en `127.0.0.1`
B-29	Informativa	La API de BunkerWeb responde en la red `app`
B-30	Baja	`local_infile` y GLPI->MariaDB sin TLS
B-31	Media	CVE críticas sin parche en las imágenes de terceros (exención escrita)
B-33	Baja	Doce avisos de endurecimiento de contenedores (CIS)
B-36	Media	El limitador del WAF banea a una persona real

13. Comparación con la Entrega 3

Aspecto	Entrega 3	Esta auditoría
ZAP	*baseline*, con y sin WAF (0 FAIL; 56 y 58 PASS) y un activo sin WAF (0 FAIL, 110 PASS)	**Activo** autenticado en tres posiciones (0 FAIL; 137 a 142 PASS)
sqlmap	nivel 3 con y sin WAF	nivel 3 por el WAF y **nivel 5** directo con `Host` y segundo orden
Autenticación de los escáneres	RRHH	RRHH, técnico, administrador, auditor y solicitante (cobertura por rol)
Control positivo del escáner	no	sí, antes de creerles
Neutralización y restauración	parcial	sí, en cada corrida
Triage de alertas	descriptivo	cada Media o superior reproducida a mano
Trivy	5 imágenes (con `postgres:17`)	5 imágenes, **con KEV y EPSS**, reescaneadas tras reconstruir
Docker Bench, Nikto, nmap, testssl, bases	sí	sí, repetidos con los mismos resultados
Puntaje de riesgo	severidad cualitativa	DREAD, factor de posición y score global

14. Límites

- Los tramos internos (aplicación->PostgreSQL, worker->GLPI, GLPI->MariaDB) no usan TLS y dependen de redes internas de Docker (B-30, B-32).

- La cobertura de la superficie de ZAP quedó en 90,9 %, por debajo del 95 % del plan.
- Un escáner solo ve las rutas que alcanza con una sesión: lo no alcanzable lo cubren otras pruebas, pero no es lo mismo.
- No se corrió ninguna prueba activa contra Supabase Auth ni contra otros terceros.